Mini Project

Mata Kuliah Basis Data

Nami Data: Web Monitoring Tinggi Gelombang Laut

Dosen Pengampu:

Willdan Aprizal Arifin, S.Pd., M.Kom.

Disusun Oleh:

Ade Rasyah Maulana

2504053

PROGRAM STUDI SISTEM INFORMASI KELAUTAN

UNIVERSITAS PENDIDIKAN INDONESIA

2026

1. Pendahuluan

1.1 Latar Belakang

Tugas UTS praktikum Sistem Basis Data meminta saya membuat aplikasi web yang memakai MySQL sebagai tempat menyimpan data dan PHP sebagai pengolahnya. Aplikasi itu harus punya halaman login dan logout, pembagian peran antara admin dan petugas, serta fitur menambah, melihat, mengubah, dan menghapus data, dan semuanya harus bertumpu pada rancangan tabel yang saling berelasi. Dari studi kasus yang bisa dipilih, saya mengambil pemantauan tinggi gelombang laut karena datanya mudah dibayangkan. Ada tempat pengamatan, ada orang yang mencatat, ada angka yang berubah dari waktu ke waktu, dan ada orang lain yang bertanggung jawab atas seluruh sistemnya.

Aplikasi yang saya bangun saya beri nama Nami Data dengan subjudul Portal Pemantauan Tinggi Gelombang. Wilayah yang dipantau ada tiga, yaitu Anyer, Pelabuhan Merak, dan Labuan, yang semuanya berada di pesisir Banten dan di basis data sudah dilengkapi dengan koordinatnya. Setiap lokasi punya satu stasiun pengamatan. Petugas mencatat tinggi gelombang dalam meter, periode gelombang dalam detik, dan suhu air dalam derajat Celsius pada waktu tertentu, sedangkan admin memegang kendali atas data tersebut, termasuk menambah, mengubah, dan menghapusnya.

Supaya data tidak berhenti sebagai deretan angka, aplikasi mengelompokkan tinggi gelombang ke dalam tiga kondisi. Tinggi di bawah satu meter dianggap rendah atau normal, mulai satu meter sampai sebelum dua meter dianggap sedang atau waspada, dan dua meter ke atas dianggap tinggi atau bahaya. Batas ini saya tentukan sendiri untuk keperluan tugas dan bukan standar resmi dari lembaga mana pun.

1.2 Tujuan Penulisan

Laporan ini saya tulis untuk menceritakan bagaimana masalahnya saya analisis, bagaimana basis datanya dirancang dan dinormalisasi, bagaimana rancangan itu saya wujudkan dalam kode PHP, dan bagaimana hasilnya saya uji. Saya juga menuliskan apa adanya bagian yang ternyata belum memenuhi ketentuan tugas. Menurut saya laporan yang jujur soal kekurangannya lebih berguna daripada laporan yang tampak sempurna tetapi tidak bisa dipertanggungjawabkan ketika saya diminta menjelaskan kode saat demonstrasi.

1.3 Perangkat yang Digunakan

Basis data yang dipakai adalah MySQL dan koneksinya dibuat dengan ekstensi mysqli milik PHP. Konfigurasi koneksi masih bersifat lokal, yaitu server localhost dengan pengguna

root dan basis data bernama uts, sehingga aplikasi dijalankan dari server web di komputer sendiri. Tampilan dibuat dengan Bootstrap 5.0.2 dan Bootstrap Icons, huruf Plus Jakarta Sans dari Google Fonts, dan grafik garis dengan Chart.js versi 4.4.1. Seluruh berkas aplikasi saya simpan dalam repositori Git yang sampai laporan ini ditulis baru memuat dua commit, yang pertama untuk kerangka awal dan yang kedua untuk fitur tambah dan ubah data pengukuran.

2. Analisis Masalah

2.1 Gambaran Masalah

Pencatatan gelombang yang dilakukan tanpa sistem biasanya berakhir di lembar kertas atau berkas spreadsheet yang tersebar di tangan masing-masing petugas. Masalah yang muncul dari cara seperti itu cukup mudah ditebak. Data dari Anyer, Merak, dan Labuan sulit dibandingkan karena format catatannya bisa berbeda, tidak selalu jelas siapa yang mencatat suatu angka, dan tidak ada yang bisa langsung melihat apakah gelombang sedang naik. Kalau semua orang bebas mengubah angka, kita juga sulit memastikan bahwa data yang tersimpan masih bisa dipercaya.

Dari gambaran itu saya menyimpulkan bahwa yang dibutuhkan adalah satu tempat penyimpanan data yang terpusat, yang menyimpan setiap pengukuran lengkap dengan stasiun, waktu, dan orang yang bertanggung jawab, serta membatasi siapa yang boleh melakukan apa. Basis data relasional cocok untuk keperluan ini karena hubungan antara stasiun, lokasi, petugas, dan pengukuran bisa dijaga oleh sistemnya sendiri lewat primary key dan foreign key, tidak bergantung pada kedisiplinan pengguna.

2.2 Pengguna dan Kebutuhan

Ada dua jenis pengguna dalam aplikasi ini. Petugas adalah orang di lapangan yang datanya dipakai untuk mengisi pengukuran, dan untuk saat ini hak petugas di aplikasi terbatas pada melihat. Setelah login, petugas melihat angka pengukuran terbaru, sebuah kartu status kondisi gelombang, grafik dari sepuluh pengukuran terakhir, dan tabel seluruh data. Admin melihat hal yang serupa ditambah ringkasan jumlah petugas, jumlah stasiun, jumlah data, dan jumlah pengukuran yang masuk kategori bahaya, dan admin satu-satunya yang disediakan tombol untuk menambah, mengubah, dan menghapus pengukuran.

2.3 Kebutuhan Data

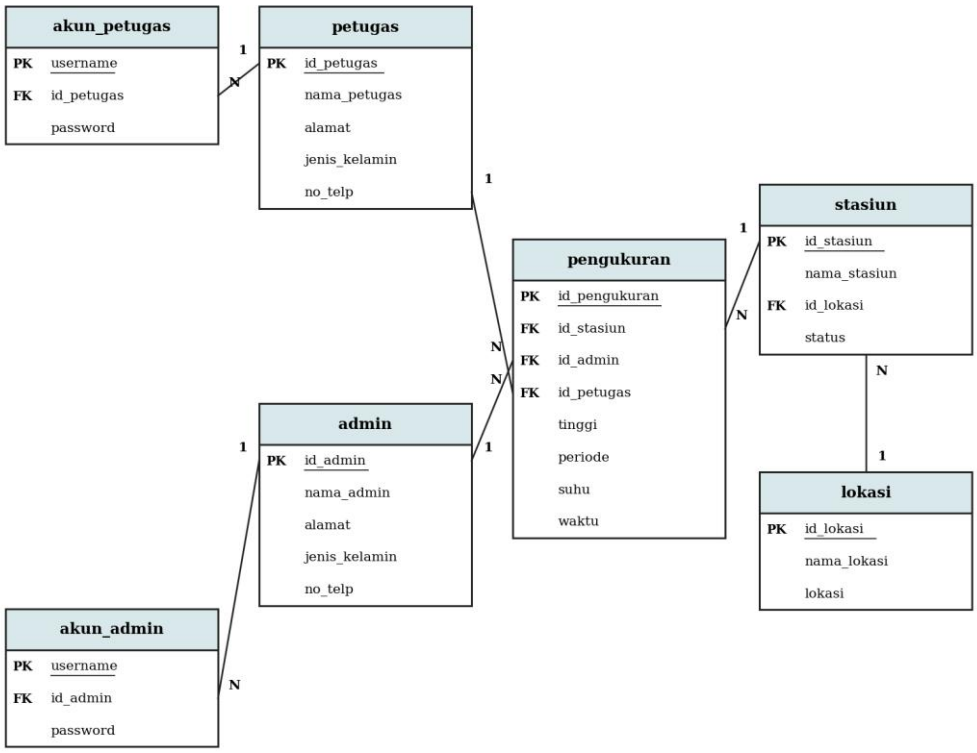
Dari kebutuhan di atas saya menemukan enam hal yang perlu disimpan. Pertama data petugas dan data admin, yang masing-masing berisi nama, alamat, jenis kelamin, dan nomor

telepon. Kedua akun masuk untuk keduanya, yang berisi username dan password. Ketiga lokasi, yang berisi nama tempat dan koordinatnya. Keempat stasiun, yang berdiri di suatu lokasi dan punya status aktif atau tidak. Kelima dan terakhir pengukuran, yang mencatat tinggi, periode, suhu, dan waktu serta menunjuk ke stasiun, admin, dan petugas yang terkait. Lokasi dan stasiun sengaja saya pisahkan supaya kalau suatu saat satu lokasi punya lebih dari satu stasiun, data lokasinya tidak perlu ditulis berulang.

3. Perancangan Basis Data

3.1 Entity Relationship Diagram

Hasil analisis kebutuhan data saya gambarkan dalam ERD pada Gambar 1. Diagram ini memuat tujuh tabel, yaitu petugas, akun_petugas, admin, akun_admin, lokasi, stasiun, dan pengukuran. Nama tabel dan kolom pada gambar sudah saya samakan dengan berkas SQL yang dikumpulkan supaya laporan, diagram, dan basis data tidak saling bertentangan.



Gambar 1. ERD aplikasi Nami Data

Cara membaca diagram ini paling mudah dimulai dari tabel pengukuran di bagian tengah, karena tabel itulah yang menjadi pusat seluruh data. Setiap baris pengukuran menunjuk ke satu stasiun lewat id_stasiun, ke satu petugas lewat id_petugas, dan ke satu

admin lewat id_admin. Sebaliknya satu stasiun, satu petugas, dan satu admin bisa muncul di banyak baris pengukuran, sehingga ketiganya berhubungan satu ke banyak dengan pengukuran. Stasiun sendiri berdiri di satu lokasi lewat id_lokasi, dan satu lokasi bisa menampung banyak stasiun, jadi hubungannya juga satu ke banyak.

Di sisi kiri diagram ada dua tabel akun. Tabel akun_petugas dan akun_admin masing-masing menyimpan username sebagai primary key, password, dan satu foreign key yang menunjuk ke pemiliknya. Dalam kenyataan satu orang saya maksudkan hanya punya satu akun, tetapi skema yang saya tulis belum memaksakan hal itu karena kolom id_petugas dan id_admin pada tabel akun belum diberi batasan UNIQUE. Secara teknis seorang petugas masih bisa punya lebih dari satu akun, dan ini saya catat sebagai bahan perbaikan.

3.2 Normalisasi

Untuk menjelaskan normalisasi, saya mulai dari bayangan kalau semua data dimasukkan ke dalam satu tabel besar. Tabel itu akan memiliki kolom waktu, tinggi, periode, dan suhu, lalu di sampingnya nama stasiun, nama lokasi dan koordinatnya, nama petugas beserta alamat dan nomor teleponnya, nama admin beserta alamat dan nomor teleponnya, ditambah username dan password. Akibatnya jelas terlihat. Setiap kali seorang petugas mencatat pengukuran di Anyer, nama stasiun, koordinat lokasi, alamat, dan nomor teleponnya ikut tertulis ulang. Kalau alamat seorang petugas berubah, kita harus mengubah ratusan baris, dan kalau ada satu baris yang terlewat maka data petugas yang sama punya dua alamat berbeda.

Bentuk pertama dicapai ketika setiap kolom hanya berisi satu nilai dan tidak ada kelompok kolom yang berulang. Hampir semua tabel saya sudah memenuhi ini. Satu hal yang saya akui masih longgar adalah kolom lokasi pada tabel lokasi, yang menyimpan lintang dan bujur sekaligus dalam satu teks seperti '-6.0533, 105.9227'. Secara ketat nilai ini belum atomik. Saya biarkan karena koordinat di aplikasi ini hanya disimpan sebagai keterangan dan tidak dihitung, tetapi kalau nanti dipakai untuk peta, kolom itu sebaiknya dipecah menjadi dua kolom bertipe desimal.

Bentuk kedua menuntut agar setiap kolom non-kunci bergantung pada seluruh primary key. Karena semua tabel di basis data ini memakai primary key satu kolom, ketergantungan parsial tidak mungkin terjadi, sehingga bentuk kedua terpenuhi dengan sendirinya. Bentuk ketiga menuntut agar kolom non-kunci tidak bergantung pada kolom non-kunci yang lain, dan di sinilah pemecahan tabelnya bekerja. Nama stasiun tidak disimpan di tabel pengukuran

karena ia bergantung pada id_stasiun, bukan pada id_pengukuran, jadi ia tinggal di tabel stasiun. Hal yang sama berlaku untuk koordinat yang tinggal di tabel lokasi, serta nama dan alamat petugas dan admin yang tinggal di tabel mereka sendiri. Password juga saya pisahkan ke tabel akun karena ia bergantung pada username dan bukan pada identitas orangnya.

Ada satu keputusan kecil yang menurut saya penting, yaitu status kondisi gelombang tidak saya simpan sebagai kolom. Status rendah, sedang, dan tinggi dihitung langsung dari nilai tinggi ketika halaman ditampilkan. Kalau status disimpan, ia akan menjadi data turunan yang bergantung pada kolom tinggi, dan suatu saat bisa tidak cocok dengan tingginya sendiri bila salah satunya diubah tanpa yang lain. Kolom status yang ada di tabel stasiun adalah hal yang berbeda, karena itu menyimpan keadaan stasiun, yaitu aktif atau tidak.

Tentu rancangan ini bukan satu-satunya cara. Struktur tabel petugas dan admin hampir kembar, dan tabel akun_petugas dan akun_admin juga. Contoh tabel pengguna pada soal tugas menyatukan semuanya dalam satu tabel users dengan kolom peran. Saya memilih memisahkannya sejak awal karena saya membayangkan petugas dan admin sebagai dua entitas yang berbeda, tetapi konsekuensinya baru terasa ketika membuat proses login, yang harus memeriksa dua tabel secara bergantian, dan hak akses jadi bergantung pada tabel mana yang cocok. Saya bahas dampaknya lebih lanjut di bagian evaluasi.

3.3 Implementasi Skema dalam SQL

Skema saya tuangkan ke dalam berkas uts.sql. Tabel dibuat dengan urutan yang memperhatikan relasi, yaitu tabel induk lebih dulu dan tabel anak sesudahnya. Petugas dibuat sebelum akun_petugas, admin sebelum akun_admin, lokasi sebelum stasiun, dan stasiun, admin, serta petugas sebelum pengukuran, supaya perintah foreign key tidak menunjuk ke tabel yang belum ada. Setiap foreign key diberi nama yang eksplisit, misalnya fk_stasiun_lokasi dan fk_pengukuran_stasiun, agar mudah dikenali kalau ada pesan galat.

Untuk data awal, saya memasukkan dua petugas, dua admin, tiga lokasi, tiga stasiun, dan sembilan baris pengukuran. Kesembilan pengukuran itu bertanggal 25 Oktober 2026 dari pukul 08.00 sampai 08.40 dengan selang lima menit, bergantian di ketiga stasiun, dengan tinggi gelombang antara 0,85 sampai 1,75 meter. Password awal keempat akun tidak disimpan sebagai teks, melainkan diubah dengan fungsi md5 pada saat dimasukkan. Password demonstrasi sengaja tidak saya tuliskan di laporan ini karena ketentuan tugas meminta password disampaikan secara terpisah.

4. Implementasi Aplikasi

4.1 Struktur Berkas

Aplikasi terdiri dari sebelas berkas PHP yang semuanya berada dalam satu folder. Berkas koneksi.php menyimpan pengaturan koneksi dan dipanggil oleh berkas lain dengan perintah include. Alur masuk dan keluar dipegang oleh login.php, proses_login.php, dan logout.php. Dua halaman utama adalah main.php untuk petugas dan main_admin.php untuk admin. Operasi data pengukuran dibagi menjadi pasangan halaman dan prosesnya, yaitu tambah_pengukuran.php dengan proses_tambah.php, edit_pengukuran.php dengan proses_update.php, dan hapus_pengukuran.php yang langsung memproses tanpa halaman tersendiri.

4.2 Autentikasi

Pengguna memulai dari login.php, yang berisi formulir dengan kolom username dan password serta tombol kecil untuk melihat atau menyembunyikan password. Formulir ini mengirim isinya dengan metode POST ke proses_login.php. Di sana saya mencocokkan username dan password terhadap tabel akun_petugas yang digabung dengan tabel petugas, dengan password dari formulir diubah memakai md5 sebelum dibandingkan. Kalau ada baris yang cocok, nama petugas disimpan ke variabel sesi dan pengguna diarahkan ke main.php.

Kalau pencarian di tabel petugas tidak menemukan apa-apa, proses yang sama diulang pada tabel akun_admin yang digabung dengan tabel admin. Jika cocok, nama admin dan penanda peran admin disimpan ke sesi dan pengguna diarahkan ke main_admin.php. Jika kedua pencarian gagal, pengguna dikembalikan ke login.php tanpa pesan apa pun. Cara ini kebetulan memenuhi ketentuan bahwa pesan kesalahan tidak boleh membocorkan apakah username atau password tertentu terdaftar, walaupun sebenarnya pengguna juga tidak diberi tahu bahwa loginnya gagal.

Setiap halaman utama memulai dengan session_start dan memeriksa apakah variabel sesi nama sudah ada. Kalau belum, pengguna dilempar kembali ke login.php. Untuk keluar, pengguna menekan tombol Keluar yang mengarah ke logout.php, yang menghancurkan sesi dengan session_destroy lalu mengarahkan pengguna ke halaman login.

4.3 Dashboard

Dashboard petugas dibuka dari main.php. Halaman ini mengambil satu baris pengukuran dengan waktu paling baru untuk ditampilkan pada kartu tinggi gelombang, periode, suhu air, dan waktu pembaruan. Dari tinggi gelombang itu program menentukan

status dengan percabangan sederhana, di bawah satu meter berwarna hijau dengan tulisan Rendah, di bawah dua meter berwarna jingga dengan tulisan Sedang, dan selebihnya berwarna merah dengan tulisan Tinggi. Sepuluh pengukuran terakhir diambil untuk grafik garis dan diurutkan ulang dengan array_reverse supaya grafiknya berjalan dari yang paling lama ke yang paling baru. Seluruh pengukuran juga ditampilkan dalam tabel di bagian bawah.

Dashboard admin dibuka dari main_admin.php dan bentuknya mirip, tetapi isinya lebih lengkap. Bagian atas berisi empat kartu angka hasil perintah COUNT, yaitu jumlah petugas, jumlah stasiun, jumlah pengukuran yang tingginya dua meter atau lebih, dan jumlah seluruh pengukuran. Tabel pengukurannya memakai INNER JOIN ke tabel stasiun dan petugas sehingga yang tampil adalah nama stasiun dan nama petugas, bukan nomor id. Di ujung setiap baris ada tombol Edit dan Delete, dan di atas tabel ada tombol Tambah Data. Label status di tabel admin memakai istilah Normal, Waspada, dan Bahaya.

4.4 Pengelolaan Data Pengukuran

Menambah data dilakukan lewat tambah_pengukuran.php. Formulirnya berisi pilihan stasiun, isian tinggi, periode, dan suhu, isian waktu yang otomatis terisi dengan waktu saat halaman dibuka, serta pilihan petugas dan admin. Isiannya dikirim ke proses_tambah.php yang menyusun perintah INSERT ke tabel pengukuran, lalu mengarahkan pengguna kembali ke dashboard admin bila berhasil. Melihat data dilakukan di tabel dashboard seperti sudah saya jelaskan sebelumnya.

Mengubah data dimulai dari tombol Edit yang membuka edit_pengukuran.php dengan membawa waktu pengukuran pada alamat URL. Formulir ubah berisi isian yang sama dengan formulir tambah, kecuali waktu dan admin yang tidak bisa diubah. Hasilnya dikirim ke proses_update.php yang menjalankan perintah UPDATE berdasarkan id_pengukuran. Menghapus dilakukan lewat tombol Delete, yang lebih dulu memunculkan kotak konfirmasi dari JavaScript dan kalau disetujui membuka hapus_pengukuran.php untuk menjalankan perintah DELETE.

4.5 Pengamanan yang Sudah Diterapkan

Beberapa hal sudah saya perhatikan sejak awal. Semua nilai dari basis data yang ditulis ke halaman dibungkus fungsi htmlspecialchars, sehingga teks yang mengandung tanda kurung sudut tidak dijalankan browser sebagai HTML. Data untuk grafik dikirim ke JavaScript lewat json_encode dengan opsi yang meloloskan karakter berbahaya. Formulir

tambah dan ubah memakai atribut required, min, dan tipe number agar isian kosong atau tidak masuk akal ditolak di browser. Di sisi basis data, kolom wajib diberi NOT NULL dan hubungan antartabel dijaga oleh foreign key. Password tidak disimpan sebagai teks biasa tetapi sebagai hasil md5. Bagian ini adalah yang bisa saya banggakan, dan sisanya, sebagaimana akan terlihat di bab evaluasi, masih jauh dari sempurna.

5. Pengujian

Ketentuan tugas meminta sembilan skenario pengujian. Hasil di bab ini saya peroleh dengan menelusuri alur kode dan skrip SQL untuk setiap skenario, dan tangkapan layar pelaksanaan pengujian di aplikasi yang berjalan saya lampirkan terpisah pada bagian lampiran. Saya menuliskan hasilnya seperti adanya, termasuk yang gagal, sebab justru dari yang gagal itulah perbaikan berikutnya bisa ditentukan.

5.1 Login dengan Kredensial Benar

Skenario pertama berhasil. Username dan password milik petugas membawa pengguna ke main.php, dan username dan password milik admin membawa pengguna ke main_admin.php, karena kedua kombinasi cocok dengan baris di tabel akun masing-masing. Ada satu kekeliruan kecil di login.php. Halaman itu punya dua pemeriksaan sesi yang sama persis, keduanya memeriksa variabel nama, sehingga admin yang sudah login lalu membuka halaman login lagi akan diarahkan ke dashboard petugas, bukan dashboard admin.

5.2 Login dengan Kredensial Salah

Kredensial yang tidak cocok dengan akun mana pun membuat pengguna kembali ke halaman login tanpa sesi apa pun. Hasil ini sesuai harapan, tetapi saya menemukan celah yang jauh lebih serius pada proses yang sama. Username dan password dimasukkan langsung ke dalam teks perintah SQL tanpa prepared statement, sehingga isian berbentuk perintah SQL, misalnya yang diawali tanda kutip tunggal, dapat mengubah makna query dan berpotensi meloloskan penyerang tanpa password yang benar. Jadi bagian ini saya nilai lulus untuk penggunaan biasa tetapi tidak aman terhadap serangan.

5.3 Akses Halaman Internal Sebelum Login

Hasilnya hanya sebagian berhasil. Halaman main.php dan main_admin.php memeriksa sesi dan melempar pengguna ke login.php. Namun halaman tambah_pengukuran.php, edit_pengukuran.php, hapus_pengukuran.php, proses_tambah.php, dan proses_update.php tidak memeriksa sesi sama sekali. Orang yang belum login dan mengetahui alamatnya bisa membuka formulir tambah, dan lebih buruk lagi

bisa memanggil alamat hapus_pengukuran.php beserta parameter waktu untuk menghapus data.

5.4 Logout

Logout berjalan sebagaimana mestinya. Setelah logout.php menghancurkan sesi, membuka main.php atau main_admin.php lewat tombol kembali di browser akan memicu pemeriksaan sesi yang gagal dan pengguna diarahkan ke halaman login. Pengujian ini lulus untuk halaman yang memang memeriksa sesi, sementara halaman yang tidak memeriksa sesi, seperti dibahas pada skenario sebelumnya, tentu tidak terpengaruh oleh logout.

5.5 Petugas Membuka Fitur Admin Lewat URL

Skenario ini gagal. Pada saat login, peran hanya dicatat untuk admin, sedangkan petugas tidak diberi penanda peran sama sekali. Lebih jauh, main_admin.php hanya memeriksa apakah variabel nama ada, bukan apakah perannya admin. Akibatnya petugas yang sudah login cukup mengetik main_admin.php di URL untuk masuk ke dashboard admin lengkap dengan tombol tambah, ubah, dan hapus. Ini kelemahan terbesar dari sisi hak akses karena persis menyalahi pesan dalam soal bahwa menyembunyikan tombol saja tidak cukup dan pemeriksaan harus dilakukan di server.

5.6 Operasi Tambah, Tampil, Ubah, dan Hapus

Tampil data berjalan baik di kedua dashboard. Tambah data bermasalah karena tabel pengukuran memakai id_pengukuran sebagai primary key tanpa AUTO_INCREMENT, sementara perintah INSERT di proses_tambah.php tidak mengisi kolom itu. Pada mode SQL yang ketat perintah tersebut ditolak, dan pada mode longgar baris pertama masuk dengan id nol lalu baris berikutnya gagal karena kunci ganda. Ubah data juga bermasalah karena formulir edit_pengukuran.php menuliskan id_pengukuran dengan nilai tetap 1 dan mengisi kolomnya dengan angka contoh, bukan dengan data baris yang dipilih, sehingga setiap pengubahan sebenarnya mengenai baris nomor 1. Hapus data berjalan, tetapi baris yang dihapus ditentukan oleh kolom waktu, bukan id_pengukuran, sehingga dua pengukuran dengan waktu yang sama akan terhapus bersamaan.

5.7 Input Tidak Valid

Penolakan input tidak valid hanya terjadi di browser lewat atribut required dan min pada formulir. Di sisi server, proses_tambah.php dan proses_update.php menerima nilai dari POST apa adanya tanpa pemeriksaan tipe, rentang, atau keberadaan. Orang yang mengirim permintaan langsung, tanpa lewat formulir, bisa mengirim nilai apa saja. Basis data hanya

menolak sebagian di antaranya, misalnya id_stasiun yang tidak ada di tabel stasiun, karena foreign key.

5.8 Password Tidak Tersimpan sebagai Teks Biasa

Skenario ini terpenuhi sebagian. Kolom password di kedua tabel akun berisi hasil md5 dan bukan password aslinya, sehingga siapa pun yang membuka tabel tidak langsung melihat kata sandi. Hanya saja md5 adalah fungsi yang cepat dan tanpa salt, sehingga password yang pendek atau umum bisa ditebak dengan mudah memakai tabel hash yang tersedia luas. Ketentuan tugas secara khusus menyebut password_hash dan password_verify, jadi cara saya belum sesuai.

5.9 Pelanggaran Foreign Key

Aplikasi tidak menyediakan fitur untuk menghapus data induk seperti stasiun, petugas, atau admin, jadi pelanggaran yang paling mungkin terjadi hanyalah menambah atau mengubah pengukuran dengan id induk yang tidak ada. Dalam kasus itu MySQL menolak perintahnya karena foreign key. Cara aplikasi menangani penolakan tersebut belum baik. Pada proses_tambah.php pesan galat mentah dari mysqli_error ditampilkan ke layar, yang membuka rincian struktur basis data kepada pengguna, sedangkan pada proses_update.php pengguna hanya dikembalikan ke halaman edit tanpa penjelasan.

5.10 Ringkasan Hasil

No	Skenario	Hasil
1	Login dengan kredensial benar	Berhasil
2	Login dengan kredensial salah ditolak	Berhasil
3	Halaman internal sebelum login	Langsung kehalaman login
4	Logout mengakhiri akses	Berhasil
5	Petugas membuka fitur admin lewat URL	Gagal
6	Tambah, tampil, ubah, hapus	Berhasil
7	Input tidak valid ditolak	Hanya di sisi browser
8	Password bukan teks biasa	memakai md5
9	Pelanggaran foreign key	Ditolak basis data, penanganan belum baik

Tabel 1. Ringkasan hasil pengujian

6. Evaluasi dan Rencana Perbaikan

Ketika menyusun bab pengujian, saya menyadari bahwa pekerjaan saya paling kuat di bagian tampilan dan paling lemah di bagian yang justru ditekankan oleh soal, yaitu keamanan dan integritas data. Dashboard terlihat rapi dan grafiknya bekerja, tetapi di balik

itu banyak hal yang belum aman. Saya kelompokkan temuannya menurut hal yang paling mendesak.

Yang pertama dan paling berbahaya adalah seluruh query yang menerima input pengguna masih disusun dengan menyambung teks. Ini berlaku di proses_login.php, proses_tambah.php, proses_update.php, dan hapus_pengukuran.php. Perbaikannya adalah mengganti semuanya dengan prepared statement milik mysqli, dengan tanda tanya sebagai penampung nilai dan bind_param untuk mengikat nilainya. Di saat yang sama saya perlu memeriksa input di sisi server, misalnya memastikan tinggi, periode, dan suhu berupa angka dalam rentang yang wajar, dan memastikan id stasiun, petugas, dan admin benar-benar ada.

Yang kedua adalah autentikasi dan hak akses. Password perlu disimpan dengan password_hash dan diperiksa dengan password_verify, dan itu berarti kolom password harus diperlebar menjadi VARCHAR(255) karena hash yang dihasilkan lebih panjang dari yang muat di kolom lima puluh karakter sekarang. Setelah login berhasil, saya perlu memanggil session_regenerate_id agar pembajakan sesi lebih sulit, dan menyimpan peran untuk kedua jenis pengguna. Lalu setiap halaman, termasuk semua berkas proses, harus memeriksa sesi dan peran di bagian paling atas. Satu cara rapi untuk itu adalah membuat sebuah berkas pembantu yang berisi fungsi pemeriksaan, lalu memanggilnya dari tiap halaman. Penghapusan sebaiknya diubah dari tautan GET menjadi formulir POST yang dilengkapi token CSRF, karena tautan GET bisa terpicu hanya dengan membuka alamat tertentu.

Yang ketiga adalah beberapa kekeliruan di basis data dan di kode yang memengaruhi kebenaran data. Kolom tinggi, periode, dan suhu pada tabel pengukuran dideklarasikan sebagai DECIMAL tanpa ketelitian. Di MySQL, DECIMAL tanpa tanda kurung berarti DECIMAL(10,0), yang tidak punya angka di belakang koma. Akibatnya nilai seperti 1,25 dan 0,95 disimpan sebagai 1 dan 1, dan status gelombang yang dihitung dari tinggi bisa meleset, misalnya tinggi 0,95 yang seharusnya normal akan terbaca sebagai waspada. Kolom itu perlu diubah menjadi DECIMAL(4,2) atau yang serupa. Kolom no_telp bertipe INT padahal nomor telepon sebelas digit melebihi batas INT dan angka nol di depannya juga hilang, jadi tipenya perlu diganti menjadi VARCHAR. Kolom id_pengukuran perlu diberi AUTO_INCREMENT. Kolom status pada tabel stasiun salah ketik menjadi stastus di berkas SQL padahal ERD menuliskannya status. Data awal lokasi memasukkan teks kosong ke kolom id yang berisi angka otomatis, yang di sebagian pengaturan MySQL menimbulkan galat dan sebaiknya diganti dengan NULL. Terakhir, kolom id_petugas dan id_admin pada tabel akun perlu diberi UNIQUE bila memang satu orang hanya boleh punya satu akun.

Yang keempat adalah kekeliruan kecil di kode. Formulir edit harus mengambil baris sesuai id_pengukuran yang dipilih, mengisi kolomnya dari baris itu, dan menyimpan id tersebut di kolom tersembunyi. Pilihan stasiun, petugas, dan admin di formulir yang saat ini ditulis langsung di HTML sebaiknya diambil dari tabelnya. Tombol Batal di formulir edit menunjuk ke dashboard.php yang tidak ada, dan tulisan Naik 0,2 m dari sebelumnya di dashboard petugas masih berupa teks tetap, bukan hasil perhitungan. Perintah die yang menampilkan mysqli_error perlu diganti dengan pencatatan galat ke berkas log dan pesan umum untuk pengguna.

Yang kelima adalah fitur yang belum ada sama sekali, yaitu halaman manajemen pengguna untuk admin. Ketentuan tugas menyebut halaman ini sebagai halaman minimum, sedangkan aplikasi saya belum memilikinya. Saya perlu menambahkan halaman untuk melihat, menambah, mengubah, dan menonaktifkan akun, dengan kebijakan relasi yang jelas, misalnya menolak penghapusan petugas yang sudah punya data pengukuran. Selain itu saya masih perlu mempertimbangkan apakah akun sebaiknya disatukan ke tabel users dengan kolom peran seperti pada contoh soal, karena pemisahan dua tabel seperti sekarang membuat pemeriksaan peran harus dilakukan secara berbelit.

7. Refleksi

7.1 Mengapa password harus disimpan dalam bentuk hash?

Basis data adalah tempat yang paling sering bocor, baik karena serangan, kelalaian, maupun orang dalam yang punya akses. Kalau password tersimpan sebagai teks biasa, siapa pun yang berhasil membaca tabel langsung bisa masuk sebagai siapa saja, dan karena banyak orang memakai password yang sama di banyak layanan, kebocoran satu aplikasi kecil seperti ini bisa merembet ke akun mereka di tempat lain. Hash adalah fungsi satu arah, jadi yang disimpan hanyalah sidik jarinya. Saat login, aplikasi menghitung hash dari password yang diketik dan membandingkannya dengan yang tersimpan. Dalam aplikasi saya fungsi yang dipakai adalah md5, yang sebenarnya sudah dianggap lemah karena terlalu cepat dihitung dan tidak memakai salt. Untuk penggunaan sebenarnya saya perlu beralih ke password_hash, yang menambahkan salt secara otomatis dan sengaja dibuat lambat.

7.2 Apa perbedaan autentikasi dan otorisasi?

Autentikasi adalah proses memastikan siapa pengguna itu, dalam aplikasi saya dilakukan lewat pencocokan username dan password di proses_login.php. Otorisasi adalah penentuan apa yang boleh dilakukan pengguna yang sudah dikenali itu. Contohnya, petugas

dan admin sama-sama berhasil melewati autentikasi, tetapi hanya admin yang semestinya boleh menambah, mengubah, dan menghapus pengukuran. Hasil pengujian saya menunjukkan bahwa kedua hal ini bisa tidak seimbang. Autentikasi di aplikasi saya sudah ada, sedangkan otorisasinya masih bocor karena main_admin.php hanya memeriksa bahwa pengguna sudah login dan tidak memeriksa perannya.

7.3 Mengapa pemeriksaan hak akses harus dilakukan di sisi server?

Kode yang berjalan di browser berada sepenuhnya di bawah kendali pengguna. Tombol yang disembunyikan dengan CSS atau HTML masih bisa ditampilkan lagi lewat alat pengembang browser, dan alamat halaman yang tidak ditautkan di mana pun tetap bisa diketik langsung. Permintaan ke server juga bisa dibuat tanpa browser sama sekali, misalnya dengan curl. Server satu-satunya pihak yang bisa dipercaya untuk memutuskan apakah suatu permintaan boleh diproses, karena ia memegang sesi dan data peran yang tidak bisa diubah pengguna. Pengujian nomor lima membuktikannya langsung, karena petugas tidak perlu melakukan apa-apa selain mengetik nama berkas untuk masuk ke wilayah admin.

7.4 Apa yang terjadi jika halaman CRUD tidak memeriksa session?

Halaman itu terbuka untuk siapa saja yang mengetahui alamatnya, tanpa perlu akun. Orang asing bisa menambah data palsu, mengubah angka pengukuran, atau menghapus data, dan basis data tidak punya cara mengetahui bahwa permintaan itu tidak sah. Hal ini bukan sekadar teori di aplikasi saya, karena tambah_pengukuran.php, edit_pengukuran.php, hapus_pengukuran.php, proses_tambah.php, dan proses_update.php memang belum memeriksa sesi. Untuk data pemantauan gelombang, data yang rusak tidak hanya merugikan secara administratif, tetapi juga bisa menyesatkan orang yang mengandalkannya untuk menilai kondisi laut.

7.5 Bagaimana foreign key membantu menjaga konsistensi data?

Foreign key memastikan bahwa setiap nilai pada kolom anak punya pasangan di tabel induk. Pada tabel pengukuran, id_stasiun harus ada di tabel stasiun, jadi tidak mungkin ada pengukuran dari stasiun yang tidak pernah terdaftar. Ia juga mencegah penghapusan induk yang masih dipakai. Misalnya stasiun yang sudah punya pengukuran tidak bisa dihapus begitu saja, kecuali kebijakan relasinya diatur lain, sehingga tidak ada pengukuran yang tersisa menunjuk ke stasiun yang sudah hilang. Penjagaan ini bekerja di tingkat basis data, jadi tetap berlaku walaupun kode aplikasinya keliru atau datanya dimasukkan lewat jalur lain, yang membuatnya lebih andal daripada hanya mengandalkan pemeriksaan di PHP.

7.6 Bagaimana aplikasi menangani pengguna yang mencoba mengubah data milik pengguna lain?

Dalam rancangan aplikasi saya, data pengukuran tidak dimiliki per pengguna, karena hanya admin yang boleh mengubahnya dan petugas hanya melihat. Maka penanganannya lewat pemeriksaan peran, yaitu permintaan ubah atau hapus dari bukan admin harus ditolak oleh server. Untuk kondisi sekarang, saya harus jujur bahwa penolakan itu belum ada, seperti terlihat di pengujian. Seandainya kelak petugas diizinkan mencatat pengukuran sendiri, kebijakannya perlu diperluas dengan kepemilikan. Setiap perintah ubah dan hapus menyertakan syarat bahwa id_petugas pada baris itu sama dengan id petugas yang tersimpan di sesi, bukan dengan nilai yang dikirim lewat formulir atau URL, dan peran juga tidak boleh dipercaya dari kiriman pengguna.

8. Pernyataan Penggunaan Bantuan AI

Sesuai ketentuan integritas akademik pada soal, saya menyatakan bahwa penyusunan normalisasi pada laporan ini saya minta referensi dari ai, dan untuk ui website itu pakai tamplate dari web figma yang buatan creator lain.

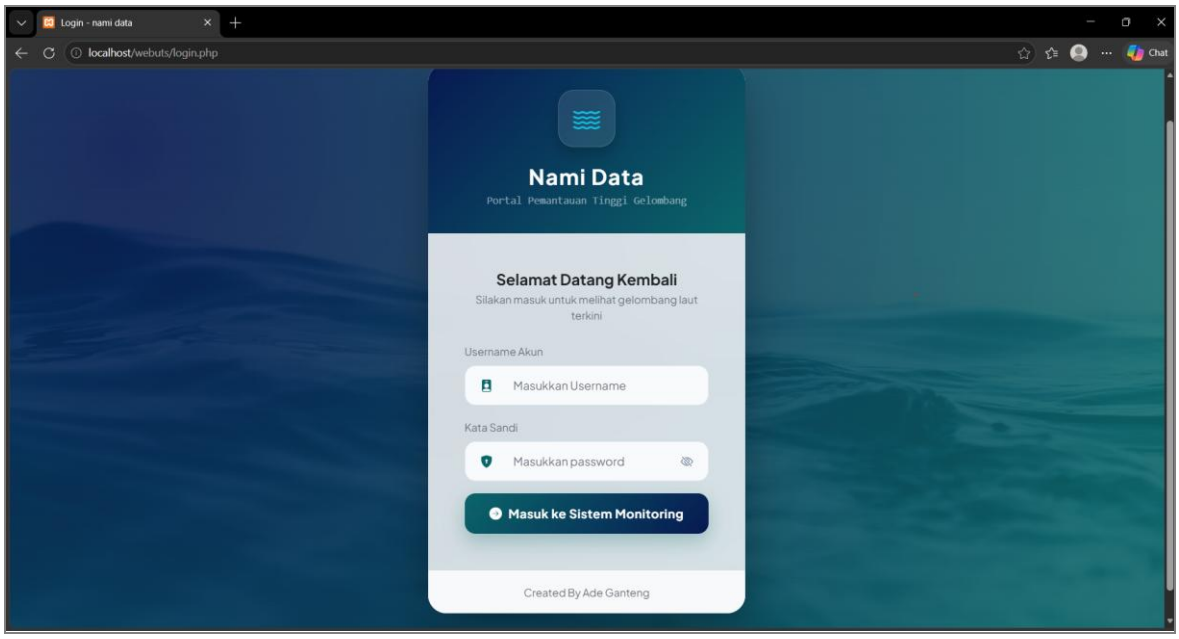
9. Penutup

Aplikasi Nami Data berhasil mewujudkan gagasan dasarnya, yaitu satu tempat untuk menyimpan dan menampilkan pengukuran tinggi gelombang dari tiga stasiun di pesisir Banten. Basis datanya terdiri dari tujuh tabel yang saling berelasi dan sudah melewati proses normalisasi sampai bentuk ketiga, dengan foreign key yang menjaga hubungan antara pengukuran, stasiun, lokasi, petugas, dan admin. Login, logout, dua dashboard, dan tampilan data bekerja, dan tampilannya sudah cukup rapi dengan grafik dan kartu status.

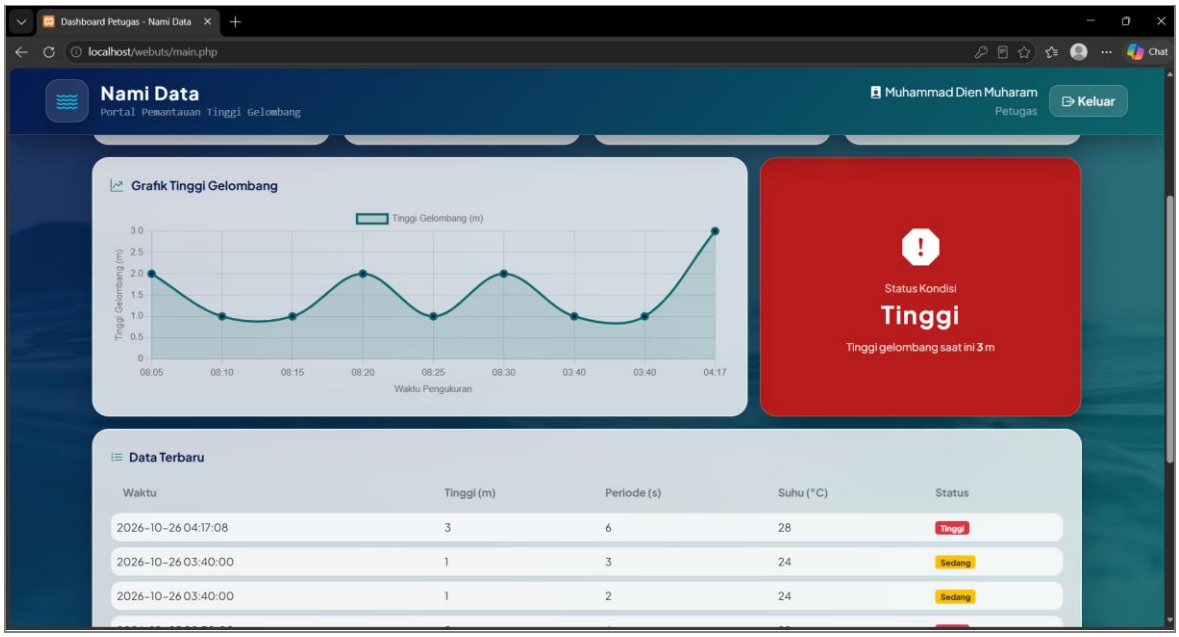
Di sisi lain, pengujian memperlihatkan bahwa aplikasi ini belum memenuhi beberapa ketentuan utama. Query belum memakai prepared statement, password masih memakai md5, pemeriksaan peran belum dilakukan di server, sebagian halaman tidak memeriksa sesi, belum ada perlindungan CSRF, halaman manajemen pengguna belum dibuat, dan ada beberapa kekeliruan pada tipe kolom serta pada fitur tambah dan ubah data. Semua itu sudah saya urutkan menurut prioritasnya pada bab evaluasi. Pelajaran terbesar yang saya dapat adalah bahwa aplikasi yang tampak berfungsi belum tentu aman, dan bahwa keamanan harus dirancang sejak awal, bukan ditambahkan sesudah tampilannya selesai.

Lampiran. Tangkapan Layar

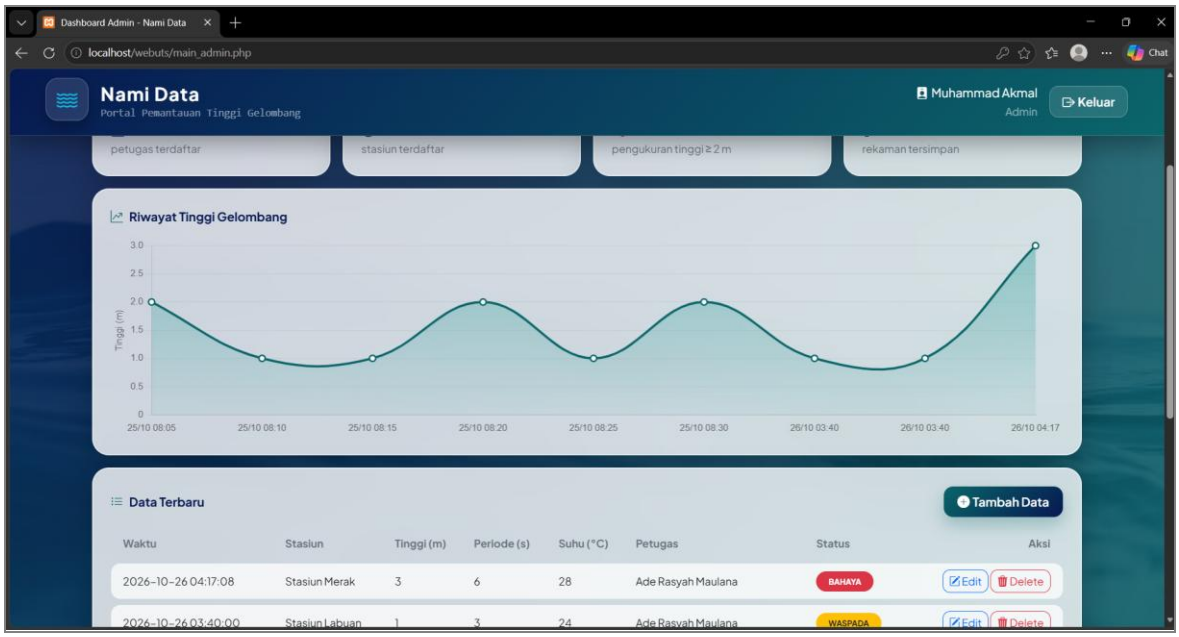
Bagian ini disediakan untuk tangkapan layar yang diminta pada ketentuan tugas, yaitu halaman login, dashboard petugas, dashboard admin, formulir tambah dan ubah data, dan hasil pengujian.



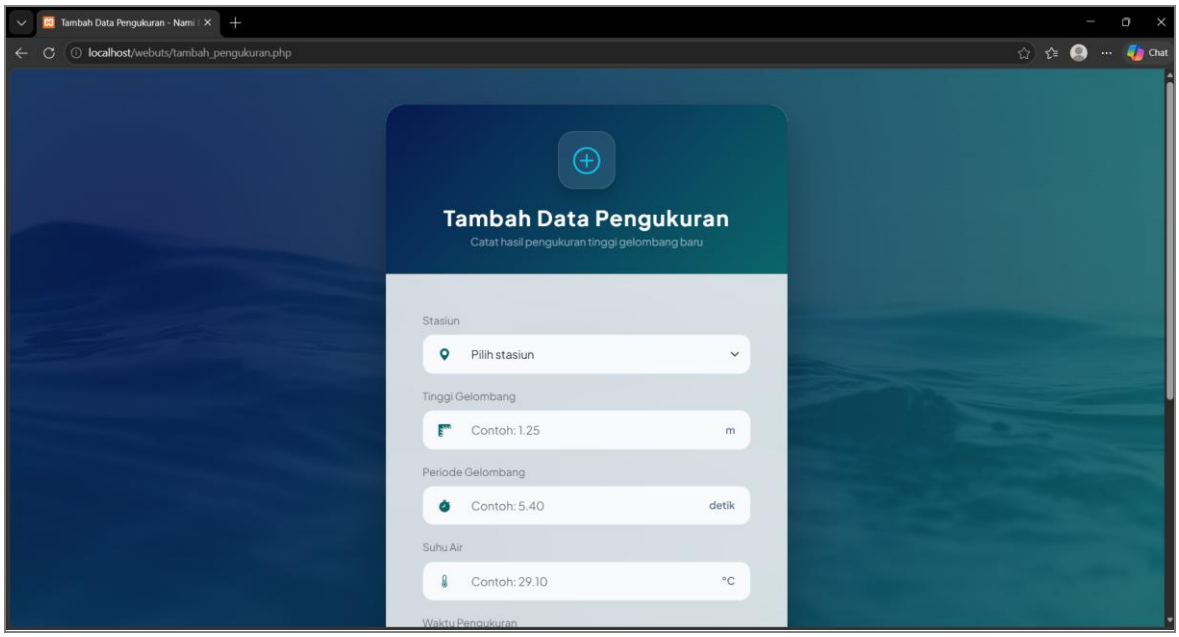
Gambar L1. Halaman login

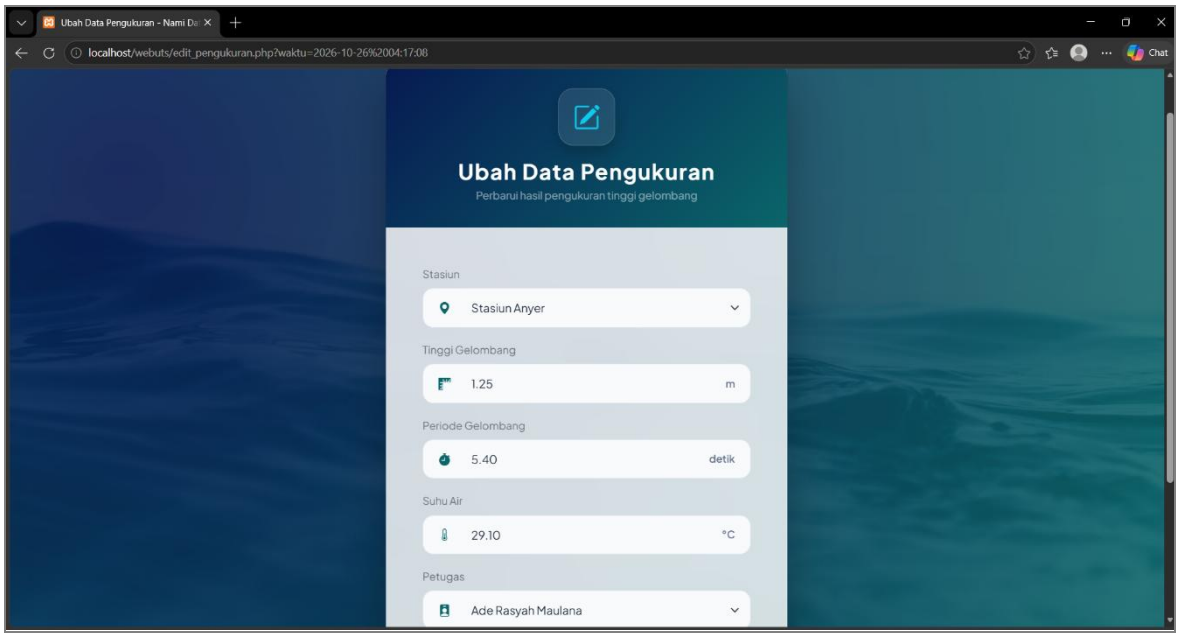


Gambar L2. Dashboard petugas



Gambar L3. Dashboard admin





Gambar L4. Formulir tambah dan ubah data